Informe de pruebas de seguridad de software

Campo	Detalle
Curso	Pruebas de Software, Unidad IV: Creación de Pruebas de Seguridad. Periodo III-26, horario sábados 8am
Código del curso	ISW-622
Integrantes	Andrey Alonso Hernández Salazar; Javier Alejandro Mendoza Gonzalez
Grupo	SC-02
Fecha de entrega	2026-10-27
Proyecto y versión	Laboratorio local de seguridad de expedientes académicos. Base v0.1.0; corregida v1.0.0
Repositorio	https://github.com/andreyhnzzz/QA-Lab1

1. Alcance, activos y flujo de datos

Se probó el laboratorio local proporcionado (Python 3.14.0, biblioteca estándar, solo en 127.0.0.1, datos y tokens ficticios). Quedan fuera TLS, autenticación real, concurrencia y despliegue.

ID	Activo	Propiedad protegida
A1	Expedientes (id, estudiante, sede, nota)	Confidencialidad e integridad
A2	Notas	Integridad
A3	Sesiones y tokens sintéticos	Autenticación
A4	Bitácora de auditoría	Trazabilidad
A5	Políticas de acceso (puede_leer, puede_modificar)	Autorización
A6	API HTTP local en 127.0.0.1:8765	Disponibilidad y validación de entrada

Flujo: cliente (curl, PowerShell o pruebas) -> `servidor.py` (extrae el token Bearer, valida longitud y JSON) -> `src/lab.py`: `autenticar` (A3) -> `puede_leer` / `puede_modificar` (A5) -> `nota_valida` -> expedientes y notas (A1, A2) -> `auditar` (A4) -> respuesta JSON con código HTTP al cliente.

2. Amenazas priorizadas

ID	Actor	Acción de abuso	Activo	Impacto	Prioridad	Req.
R-01	Estudiante	Solicita el expediente de otra persona	A1	Filtración de nota y datos personales	Alta: probabilidad alta, impacto en privacidad	SEC-01
R-02	Docente de otra sede	Cambia la nota de un expediente fuera de su sede	A2	Alteración no autorizada de notas	Crítica: afecta integridad académica	SEC-02
R-03	Titular de token revocado o vencido	Reutiliza el token	A3	Acceso tras revocación	Alta: invalida el control de sesiones	SEC-03
R-04	Docente (error o abuso)	Envía nota -1, 101, NaN o true	A2	Datos corruptos persistidos	Media: requiere cuenta docente	SEC-04
R-05	Estudiante o administrador	Intenta cambiar una nota	A2	Escalada vertical de privilegios	Alta	SEC-02
R-06	Cliente malicioso	JSON malformado, cuerpo mayor a 1024 bytes o Content-Length negativo	A6	Error o hilo bloqueado (denegación de servicio)	Media: solo local	SEC-05
R-07	Persona con acceso a bitácora o respuestas de error	Lee tokens en bitácora o datos en errores	A4	Robo de credenciales y falta de trazabilidad	Media	SEC-06, SEC-07

3. Requisitos verificables y criterios de aceptación

ID	Tipo	Requisito
SEC-01	Autorización y confidencialidad	Si un estudiante solicita un expediente ajeno, o un docente uno de otra sede, el servicio responde 403, no incluye la nota ni otros datos y no modifica registros. El administrador lee ambas sedes.
SEC-02	Integridad	Solo un docente cambia notas y solo de su sede; estudiante y administrador reciben 403 y la nota original no cambia.
SEC-03	Sesiones	Un token ausente, desconocido, revocado o vencido recibe 401 al leer y al modificar, sin datos del expediente. Tras revocar, el token deja de funcionar.

ID	Tipo	Requisito
SEC-04	Validación de la nota	La nota debe ser un número finito, no booleano, entre 0 y 100 inclusive; otro valor recibe 400 y no se persiste.
SEC-05	Validación de la API	JSON malformado o no objeto recibe 400; cuerpo mayor a 1024 bytes recibe 413; Content-Length negativo recibe 400. Ninguno modifica datos ni bloquea el servidor.
SEC-06	Confidencialidad de errores	Ninguna respuesta 400, 401, 403, 404 o 413 incluye nota, estudiante u otro dato del expediente.
SEC-07	Trazabilidad	Cada lectura o modificación autenticada se registra con usuario, acción, expediente y código; la bitácora nunca contiene tokens.

ID	Req.	Dado	Cuando	Entonces
CA-1	SEC-01	Ana autenticada con lab-ana	solicita GET /expedientes/202	recibe 403 con {"error": "Acceso denegado"}, sin nota, y la nota 91 permanece
CA-2	SEC-03	Ana con sesión revocada	solicita GET /expedientes/101	recibe 401 sin nota
CA-3	SEC-04	María autenticada	envía {"nota": 101} al expediente 101	recibe 400 y la nota 82 permanece
CA-4	SEC-02	María, docente de Central	envía una nota al expediente 202 de Pacífico	recibe 403 y la nota 91 permanece

4. Matriz de trazabilidad requisito, riesgo y prueba

Req.	Riesgo	Caso	Evidencia esperada	Estado final
SEC-01	R-01	TC-01	200; estudiante=ana; nota=82	Aprobado
SEC-02	R-02	TC-02	200; nota 85 persistida	Aprobado
SEC-01	R-01	TC-03	200 en ambos	Aprobado
SEC-01, SEC-06	R-01	TC-04	403; cuerpo sin nota ni estudiante; nota 91 intacta	Aprobado
SEC-02, SEC-06	R-02	TC-05	403; sin nota en cuerpo; nota 91 intacta	Aprobado
SEC-03	R-03	TC-06	401 en ambos; sin nota; nota intacta	Aprobado
SEC-03	R-03	TC-07	401; sin nota; nota intacta	Aprobado
SEC-02	R-05	TC-08	403; sin nota en cuerpo; nota 82 intacta	Aprobado
SEC-05	R-06	TC-09	400 en cada uno; nota 82 intacta	Aprobado
SEC-04	R-04	TC-10	200; el valor queda persistido	Aprobado
SEC-04	R-04	TC-11	400; sin nota en cuerpo; nota 82 intacta	Aprobado
SEC-05	R-06	TC-12	1024: 200; 1025: 413; -1: 400; el servidor responde	Aprobado
SEC-07	R-07	CT-01	3 registros con usuario, acción, id y código; sin tokens	Aprobado

Cobertura: los 7 requisitos tienen al menos una prueba automatizada. Anexos CSV: `matriz_trazabilidad.csv`, `casos_prueba.csv`, `hallazgos.csv`.

5. Diseño de los 12 casos (3 positivos, 6 negativos, 3 de frontera)

ID	Tipo	Req.	Precondiciones	Entradas	Pasos	Resultado esperado	Nivel
TC-01	Positivo	SEC-01	lab-ana válido; expediente 101 con nota 82	lab-ana, id 101	leer_expediente / GET /expedientes/101	200; estudiante=ana; nota=82	Unidad e integración
TC-02	Positivo	SEC-02	lab-maria (docente Central) válido; expediente 101 nota 82	lab-maria, id 101, nota 85	actualizar_nota	200; nota 85 persistida	Unidad
TC-03	Positivo	SEC-01	lab-admin válido; expedientes 101 y 202	lab-admin, ids 101 y 202	leer_expediente por cada id	200 en ambos	Unidad
TC-04	Negativo	SEC-01, SEC-06	lab-ana (Central) y lab-maria (Central) válidos; expediente 202 (Pacífico) nota 91	a) lab-ana, 202; b) lab-maria, 202	leer_expediente / GET /expedientes/202	403; cuerpo sin nota ni estudiante; nota 91 intacta	Unidad e integración
TC-05	Negativo	SEC-02, SEC-06	lab-maria (Central) válido; expediente 202 nota 91	lab-maria, 202, nota 10	actualizar_nota / POST /expedientes/202/nota	403; sin nota en cuerpo; nota 91 intacta	Unidad e integración
TC-06	Negativo	SEC-03	Sesión revocada con POST /sesiones/revocar	token revocado; lectura y cambio de nota	revocar; leer; actualizar	401 en ambos; sin nota; nota intacta	Unidad e integración
TC-07	Negativo	SEC-03	Token lab-vencida (expirada); también token ausente, vacío o desconocido	lab-vencida; sin token; lab-inexistente; vacío	leer y actualizar	401; sin nota; nota intacta	Unidad e integración
TC-08	Negativo	SEC-02	lab-ana y lab-admin válidos; expediente 101 nota 82	cada token, id 101, nota 100	actualizar_nota	403; sin nota en cuerpo; nota 82 intacta	Unidad

ID	Tipo	Req.	Precondiciones	Entradas	Pasos	Resultado esperado	Nivel
TC-09	Negativo	SEC-05	Servidor local activo; lab-maria válido	Cuerpos: {no es json; [1, 2]; {"nota": "alta"}; {"otro": 1}; {"nota": NaN}	POST /expedientes/101/nota	400 en cada uno; nota 82 intacta	Integración
TC-10	Frontera	SEC-04	lab-maria válido; expediente 101	nota 0; nota 100	actualizar_nota	200; el valor queda persistido	Unidad
TC-11	Frontera	SEC-04	lab-maria válido; expediente 101 nota 82	-1; 101; -0.01; 100.01; NaN; inf; true; "85"; null (API: -1 y 101)	actualizar_nota / POST nota	400; sin nota en cuerpo; nota 82 intacta	Unidad e integración
TC-12	Frontera	SEC-05	Servidor local activo; lab-maria válido	cuerpo de 1024 bytes; 1025 bytes; Content-Length -1	POST /expedientes/101/nota	1024: 200; 1025: 413; -1: 400; el servidor responde	Integración

Pruebas: CT-01 (SEC-07): test_unidad.test_sec07_auditoria_registra_usuario_y_no_guarda_tokens (unidad); resultado inicial Fallido, final Aprobado. Total de pruebas automatizadas: 25 (14 de unidad en `tests/test_unidad.py` y 11 de integración en `tests/test_api.py`). Los 12 casos están automatizados. Los nombres de las pruebas están en `casos_prueba.csv`.

6. Ciclos TDD rojo, verde y refactor

Los ciclos 1 y 2 son los exigidos (acceso indebido; sesión y modificación no autorizada). El ciclo 3 y H-01 son adicionales. Cada paso tiene su commit y su registro en `evidencias/` (con fecha, versión de Python y comando).

Ciclo	Rojo (commit)	Evidencia roja	Verde (commit)	Evidencia verde	Refactor (commit)	Evidencia refactor
1 (acceso indebido, SEC-01)	fc579f5	01_ciclo1_rojo.txt: 403 != 200 en TC-04a y TC-04b (2 fallos)	761a2e8	02_ciclo1_verde.txt: 5 pruebas OK	e6a4842	03_ciclo1_refactor.txt: 5 pruebas OK
2 (sesión y modificación, SEC-02/SEC-03)	ebc091f	04_ciclo2_rojo.txt: 401 != 200 (TC-06, TC-07) y 403 != 200 (TC-05) (3 fallos)	a7c983c	05_ciclo2_verde.txt: 11 pruebas OK	f269461	06_ciclo2_refactor.txt: 11 pruebas OK
3 (validación y auditoría, SEC-04/SEC-07)	1e6ce17	07_ciclo3_rojo.txt: 8 fallos (TC-11 y CT-01)	b7aeb4c	08_ciclo3_verde.txt: 14 pruebas OK	c328f7e	11_refactor_final.txt: 25 pruebas OK
H-01 (API, SEC-05)	b7aeb4c / 76293a1	09_api_rojo.txt: TimeoutError en TC-12b (1 error)	98ad2a5	10_api_verde.txt: 25 pruebas OK	c328f7e	11_refactor_final.txt: 25 pruebas OK

Cambios mínimos del verde: ciclo 1, condición de rol y propiedad en `leer_expediente`; ciclo 2, rechazo de sesiones revocadas o vencidas y comparación de sede en `actualizar_nota`; ciclo 3, `nota_valida` y bitácora sin token; H-01, rechazo de `Content-Length` negativo. **Refactor:** `puede_leer`, `puede_modificar`, `denegado()`, `autenticar` simplificado. Los registros rojos corresponden al árbol de trabajo previo al commit indicado.

7. Ejecución, pruebas manuales e inspección estática

Ejecuciones limpias (sin __pycache__), comando `python -m unittest discover -s tests -v`, Python 3.14.0, Windows 11: 25 pruebas, OK, dos veces (`14_ejecucion_limpia_1.txt` y `14_ejecucion_limpia_2.txt`). Clon limpio del repositorio: 25 pruebas OK. Suite final contra el código base: 20 fallos y 1 error (`15_suite_final_contra_base.txt`).

Pruebas manuales por API (DAST manual) con curl contra el servidor local ya corregido (`evidencias/pruebas_manuales.sh`, resultados en `12_pruebas_manuales.txt`). Los 15 resultados coincidieron con lo esperado.

ID	Solicitud	Resultado
PM-01	GET /health	200
PM-02	lab-ana lee 101 (propio)	200 con nota 82
PM-03	lab-ana lee 202 (otra sede)	403 sin nota
PM-04	lab-maria cambia nota de 202 (otra sede)	403
PM-05	nota 150	400
PM-06	JSON malformado	400
PM-07	lab-admin cambia nota	403
PM-08	lab-vencida lee 101	401
PM-09	sin token	401
PM-10	lab-maria cambia nota de 101 a 85	200
PM-11	revocar lab-ana	200
PM-12	lab-ana lee 101 tras revocar	401
PM-13	lab-admin lee 202	200
PM-14	Content-Length -1	400

ID	Solicitud	Resultado
PM-15	lab-pedro lee 202 tras los intentos rechazados	200 con nota 91 intacta

Inspección estática (SAST): lista de comprobación manual y Bandit 1.9.4 (`13_sast_bandit.txt`: 0 incidencias, resultado no concluyente para lógica de autorización).

Control	Resultado
Permisos	Cumple: lectura y cambio se deciden por rol, propiedad y sede en funciones separadas
Validación	Cumple: nota numérica finita en [0,100]; JSON objeto; límite de 1024 bytes; longitud no negativa
Manejo de errores	Cumple: códigos 400, 401, 403, 404, 413 con mensajes genéricos; sin trazas al cliente
Exposición de datos	Cumple con O-01: las denegaciones no incluyen datos; 404 frente a 403 permite enumerar ids
Auditoría	Cumple: usuario, acción, id y código; sin tokens; incluye intentos denegados

8. Inspección, usabilidad y reproducibilidad

Acta de inspección

Campo	Registro
Autor	Andrey Alonso Hernández Salazar
Revisor (persona distinta del autor)	[COMPLETAR: nombre del compañero revisor]
Fecha	[COMPLETAR]
Objetos inspeccionados	Política de acceso (puede_leer, puede_modificar) y casos TC-05 y TC-11
Observaciones	OB-1 (Baja): 404 frente a 403 permite enumerar ids (O-01). OB-2 (Baja): estado global sin locks (O-02). OB-3 (Baja): revocar devuelve 200 sobre token inválido (O-03). OB-4 (Media, prueba): TC-11 compartía estado entre subpruebas (F-01).
Acciones	OB-1 y OB-3: riesgo residual aceptado. OB-2: mejora recomendada. OB-4: corregida.

Revisión de las pruebas: cada prueba comprueba el efecto sobre los datos (nota intacta), crea su propio estado (`estado_inicial()` y un servidor con puerto efímero por prueba) y puede fallar cuando el control falla, como lo demuestran los rojos. TC-12 depende de un tiempo máximo de 3 s para detectar el bloqueo.

Usabilidad y mensajes

Situación	Mensaje	Valoración
Sesión inválida (ausente, revocada o vencida)	401 {"error": "No autenticado"}	Claro: indica que debe autenticarse. No distingue entre revocada, vencida o inexistente, lo que evita revelar si un token existió; el detalle queda para el diagnóstico interno.
Acceso denegado	403 {"error": "Acceso denegado"}	Claro y sin nota ni datos del expediente. Limitación: 404 en ids inexistentes permite inferir existencia (O-01).

Ajustes de mantenimiento (Fase E): se renombraron `test_rojo_*` a `test_tcNN_*`, se agregaron mensajes de diagnóstico en las aserciones y se aisló el estado de cada subprueba de TC-11. **Reproducibilidad:** el README se siguió en un clon limpio del repositorio (25 pruebas OK, sin instalar paquetes). Ejecución por un compañero usando solo el README: [COMPLETAR resultado y dificultades].

9. Registro de hallazgos

ID	Req.	Caso	Sev.	Descripción y reproducción	Esperado	Observado	Impacto	Tratamiento y commit	Estado
H-01	SEC-05	TC-12	Media	Con Content-Length: -1 el servidor llama a rfile.read(-1) y bloquea el hilo hasta que el cliente cierre. Pasos: POST /expedientes/101/nota con Content-Length: -1	400	Sin respuesta (timeout de 3 s)	Denegación de servicio por hilo bloqueado	servidor.py rechaza cantidad < 0 con 400 (98ad2a5)	Corregido y verificado
H-02	SEC-01	TC-04	Crítica	leer_expediente no verificaba rol ni propiedad. Pasos: lab-ana lee /expedientes/202; lab-maria lee /expedientes/202	403 sin nota	200 con nota 91 y datos de Luis	Filtración de expedientes ajenos	puede_leer(usuario, expediente) en leer_expediente (761a2e8)	Corregido y verificado
H-03	SEC-03	TC-06, TC-07	Alta	autenticar ignoraba los campos revocada y expirada. Pasos: Leer o modificar con lab-vencida o tras revocar	401	200 con datos	Acceso con sesiones no válidas	autenticar devuelve None si la sesión está revocada o expirada (a7c983c)	Corregido y verificado
H-04	SEC-02	TC-05	Crítica	actualizar_nota no comparaba la sede del docente con la del expediente. Pasos: lab-maria cambia la nota del expediente 202	403 y nota 91	200 y nota cambiada	Alteración de notas de otra sede	puede_modificar exige rol docente y misma sede (a7c983c)	Corregido y verificado

ID	Req.	Caso	Sev.	Descripción y reproducción	Esperado	Observado	Impacto	Tratamiento y commit	Estado
H-05	SEC-04, SEC-05	TC-09, TC-11	Alta	Se aceptaban notas fuera de [0,100], NaN, inf y booleanos (JSON NaN llegaba a la API). Pasos: nota -1, 101, NaN, inf, true	400 y nota intacta	200 y valor persistido	Datos corruptos en el expediente	nota_valida: numérico finito, no booleano, entre 0 y 100 (b7aeb4c)	Corregido y verificado
H-06	SEC-07	CT-01	Media	La bitácora guardaba el token y omitía los intentos denegados. Pasos: Leer, leer ajeno y actualizar; inspeccionar estado["auditoria"]	3 registros con usuario y código, sin token	2 registros con token	Credenciales expuestas y falta de trazabilidad	auditar(): usuario, acción, id y código; incluye 403 y 400 (b7aeb4c)	Corregido y verificado
O-01	SEC-06	-	Baja	El código 404 (no existe) frente a 403 (existe, sin permiso) permite saber si un id existe. Pasos: lab-ana pide /expedientes/999 y /expedientes/202	Misma respuesta	404 y 403 distintos	Enumeración de identificadores	No se corrige: se acepta como riesgo residual	Aceptado como riesgo residual
O-02	SEC-03	-	Baja	Estado global compartido por todos los hilos sin bloqueo. Pasos: Revisión estática de servidor.py	Acceso sincronizado	Sin locks	Condiciones de carrera con carga concurrente	Mejora recomendada; sin prueba de concurrencia	Por investigar
O-03	SEC-03	-	Baja	revocar_sesion devuelve 200 sobre un token ya revocado o vencido. Pasos: POST /sesiones/revocar con lab-vencida	Idempotente o 401	200	Mensaje poco preciso	Sin cambio: no expone datos	Aceptado como riesgo residual
F-01	SEC-04	TC-11	-	Falso positivo de la prueba: en el primer rojo, los casos "85" y None fallaron por estado contaminado por el caso True, no por el producto. Pasos: Ejecutar TC-11 con estado compartido entre subpruebas	Cada caso independiente	Fallo en cascada	Ninguno en el producto	Se reinicia estado_inicial() en cada subprueba y se regeneró el registro rojo (1e6ce17)	Corregido (fallo de la prueba)
F-02	-	-	-	Bandit no reporta incidencias; resultado no concluyente sobre defectos lógicos de autorización. Pasos: bandit -r src servidor.py	-	0 incidencias	Ninguno	Se complementa con pruebas dinámicas y lista de comprobación	Informativo

Las pruebas de cierre de cada hallazgo son las pruebas de los casos indicados; la regresión completa (25 pruebas) se ejecutó tras cada corrección y al final.

10. Indicadores y dictamen de liberación

Indicador	Fórmula	Base v0.1.0	Final v1.0.0
Casos planificados	-	12	12
Aprobados / Fallidos / Bloqueados / No ejecutados	-	5 / 7 / 0 / 0	12 / 0 / 0 / 0
Tasa de aprobación	aprobados / (aprobados + fallidos) x 100	5/12 = 41.7%	12/12 = 100%
Avance	(aprobados + fallidos) / planificados x 100	12/12 = 100%	12/12 = 100%
Cobertura de requisitos	requisitos con al menos una prueba válida / definidos x 100	7/7 = 100%	7/7 = 100%

El estado base se obtuvo ejecutando la suite final contra el código original (commit ff94b3d). Una tasa de aprobación alta no demuestra ausencia de vulnerabilidades.

Decisión: liberar con condiciones, únicamente como material didáctico en 127.0.0.1; no apto para producción. Defectos abiertos críticos o altos: 0 (H-01 a H-06 corregidos y verificados). Abiertos de severidad baja: O-01, O-02, O-03. Condiciones: no exponer fuera de localhost, no reutilizar la autenticación simulada y reevaluar antes de cualquier uso con datos reales.

Riesgo residual: enumeración de ids (404 frente a 403); condiciones de carrera no probadas; tokens estáticos sin expiración temporal real; sin TLS ni limitación de intentos. **Limitaciones:** un solo entorno, sin pruebas de concurrencia ni fuzzing, SAST con una sola herramienta, sin escaneo DAST automatizado, revisión cruzada y prueba de reproducibilidad por compañero pendientes de completar. **Responsable de la decisión (hipotético):** Andrey Hernández Salazar, rol QA.

11. Uso de IA y aportes

Se usó un asistente de IA (Claude Code) para proponer casos, pruebas y correcciones; las pruebas se ejecutaron y los resultados fueron verificados en el laboratorio local. Aportes: Andrey Alonso Hernández Salazar, diseño, pruebas, correcciones, evidencias e informe; Javier Alejandro Mendoza Gonzalez: [COMPLETAR aporte].

Commits del repositorio

```
ff94b3d Add base security lab provided by the instructor
54b6c78 Add baseline test run evidence and run script
fc579f5 test: add failing read-authorization tests for SEC-01 (cycle 1 red)
761a2e8 fix: enforce read authorization by role in leer_expediente (SEC-01, cycle 1 green)
e6a4842 refactor: extract read policy into puede_leer and shared denial response
ebc091f test: add failing session and unauthorized-update tests for SEC-02/SEC-03 (cycle 2 red)
a7c983c fix: reject revoked/expired sessions and cross-site grade updates (SEC-02/SEC-03, cycle 2 green)
f269461 refactor: extract puede_modificar and return a fresh denial response per call
1e6ce17 test: add failing grade-validation and audit tests for SEC-04/SEC-07 (cycle 3 red)
b7aeb4c feat: add nota_valida and token-free audit records (SEC-04/SEC-07, cycle 3 green)
76293a1 test: add API integration suite; negative Content-Length hangs the server (H-01 red)
98ad2a5 fix: reject negative Content-Length with 400 (H-01 green)
c328f7e refactor: shorten test server poll interval to speed up the API suite
4c554a2 docs: add manual API test log, SAST report and two clean-state suite runs
```